

Measuring Healthcare Data Leaks and Security Flaws at Internet Scale

Nico Brüggemann*, Lukas Schmidt^{†‡}, Marvin Dölzer*, Marius Brockhoff*, Fabian Ising*,
Christoph Saatjohann^{†‡}, Sebastian Schinzel*^{†‡}

*Fraunhofer SIT and National Research Center for Applied Cybersecurity ATHENE, Steinfurt, Germany
{nico.brueggemann, marvin.doelzer, marius.brockhoff, fabian.ising}@sit.fraunhofer.de

[†]FH Münster University of Applied Sciences, Steinfurt, Germany
{lukas-schmidt, christoph.saatjohann, schinzel}@fh-muenster.de

[‡]Graduate School for Applied Research in North Rhine-Westphalia (Graduate School NRW), Bochum, Germany

Abstract—Systems that process medical data should be meticulously secured. Yet, network services in healthcare environments often fail to implement basic security measures. For example, previous studies showed that network segmentation flaws led to DICOM systems leaking millions of patient records.

In addition to DICOM, healthcare facilities rely heavily on the HL7 and FHIR protocols to transmit data. For nine months, we operated a low-interaction honeypot for medical protocols. We found it was regularly scanned for DICOM but never for HL7 or FHIR, indicating that despite their widespread use and importance for patient data security, the security of these services remains underexplored.

In this paper, we present the first large-scale study on HL7 and FHIR services and expand previous work on DICOM. Our large-scale Internet scans, covering the three major healthcare protocols across IPv4 and IPv6 address spaces, identify healthcare systems and uncover data leaks due to authentication flaws. Additionally, we scanned for deficiencies in TLS configurations of these services and known insecure healthcare software.

In total, we found 2,841 healthcare services with authentication flaws. 94.4% of all exposed systems do not support transport encryption, and 1,373 systems have known software vulnerabilities, including those with potential for system takeover and CVSS scores up to 9.8. Overall, our study reveals an alarming state of cybersecurity in healthcare deployments, for which we discuss potential reasons and countermeasures. Finally, we report on the coordinated disclosure campaign we initiated to improve the security of patient data.

Index Terms—FHIR, DICOM, HL7, Healthcare Protocols, Data Leaks, Internet Measurement, IPv6

1. Introduction

Digitalization has become ubiquitous in healthcare facilities such as hospitals and medical centers. However, the long life cycles of expensive medical devices have led to the widespread adoption of outdated network protocols. These protocols often fail to implement basic security features, such as authentication or encryption, and, to protect patient data, must not be exposed to the Internet.

Nonetheless, previous studies have shown that patient data was publicly accessible due to simple network seg-

mentation flaws, e.g., on the Digital Imaging and Communications in Medicine (DICOM) network servers [1]–[6]. As a result, these studies revealed data leaks affecting millions of patients. The disclosure of these data leaks helped contain the exposure of particularly sensitive information, such as health status, medication, or Sexual Orientation and Gender Identity [7], whose public dissemination poses incalculable risks for affected persons.

Next to DICOM, which is primarily utilized for the transmission and storage of medical image data originating from X-rays or CTs, the HL7 and Fast Healthcare Interoperability Resource (FHIR) protocols are of utmost relevance in healthcare environments [8]. HL7 is used to control the Hospital Information System (HIS), which stores patient data, diagnoses, and medication doses. The FHIR standard introduces a modern, web-based successor that will become increasingly relevant in the future, and major technology companies such as Apple, Amazon, Google, IBM, and Microsoft already implemented FHIR services in their technology stacks [9]–[11].

However, to date, both HL7 and FHIR services have been overlooked by security researchers (see our honeypot experiments in Section 3). By focusing solely on DICOM, previous studies explored only a fraction of the attack surface of healthcare institutions, potentially missing further critical data leaks. To overcome these limitations, we present the first large-scale study on the security of publicly accessible HL7 and FHIR services. We further supplement our study with more thorough DICOM measurements than previously performed. For each protocol, we scanned both the IPv4 and IPv6 address spaces for data leaks, examined the use of authentication measures and transport layer security (TLS), and identified vulnerable software versions.

Our findings present an alarming state of cybersecurity in healthcare facilities. We found healthcare services disclosing patient data without authentication, systems transferring patient data without using encryption, and systems suffering from critical security vulnerabilities. We leverage the collected data to enhance patient data security and inform affected healthcare facilities during a responsible disclosure process.

Summarized, the key contributions of our work are:

- We present the results of the first, Internet-wide measurements on the security of HL7 and FHIR services and expand on the known results for

DICOM servers.

- We introduce the first study on healthcare service security in both the IPv4 and IPv6 address space.
- We introduce a low-interaction honeypot for DICOM, HL7, and FHIR protocols, and present the results of a 9 month study on healthcare protocol attacks observed in the wild.
- We identified authentication flaws in 1,780 DICOM, 903 HL7, and 242 FHIR services (2,841 total endpoints). Furthermore, we show that 94.4% of endpoints transfer patient data without encryption, and 1,373 endpoints suffer from security flaws with a CVSS score up to 9.8.
- We report all identified security flaws to operators as part of a responsible disclosure process.

2. Background

2.1. Data Transmission in Healthcare Facilities

The Hospital Information System (HIS), the central patient record storage, manages and streamlines the administrative, clinical, and financial operations of a hospital. To centralize diagnostics and laboratory or radiological findings, a HIS usually communicates with other information systems. Typical examples are the Laboratory Information System (LIS) or the Radiology Information System (RIS) [12], [13].

These systems are developed by multiple companies using various technologies [14], resulting in a heterogeneous landscape and interoperability issues [15]. The same applies to the protocols used for data exchange between these systems, e.g., DICOM, HL7, FHIR, LIS 1/2, and EDIs. Moreover, proprietary protocols by the information system and device manufacturers are often used. However, DICOM, HL7, and more recently, FHIR are considered the most widely used protocols in healthcare facilities [16], [17]. Figure 1 shows an example of communication between common information systems in a hospital.

2.2. Healthcare Protocols

2.2.1. DICOM. DICOM is a healthcare protocol used to store and transmit digital information between medical imaging devices (e.g., a CT or a MRI scanner) and other systems (e.g., a RIS or a Picture Archiving and Communication System (PACS)). DICOM was first published in 1985, and according to the Medical Imaging Technology Association (MITA), it remains one of the most widely used healthcare protocols today [18]. The DICOM standard defines a DICOM file data format and a network protocol known as the DICOM Upper Layer Protocol. The DICOM protocol enables communication between two DICOM systems, also referred to as Application Entities (AEs) [19]. AEs are identified by AE-titles and provide the usage of DICOM services, which define the functionality an AE offers to its peer.

The current version of the DICOM standard is divided into 22 parts, and unlike HL7, it defines security features. Part 15, "Security and System Management Profiles", of the DICOM standard describes support for transport encryption, digital signatures, the Secure DICOM File,

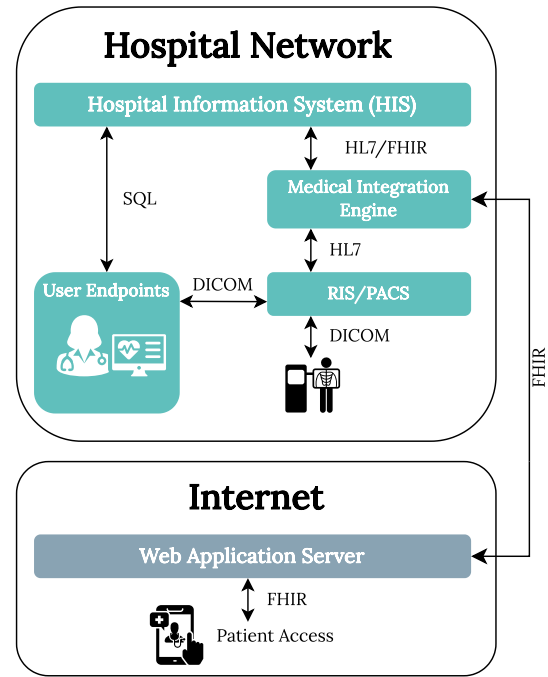


Figure 1: Exemplary transfer of data for healthcare protocols in healthcare facilities.

which allows DICOM data to be stored in an encrypted form, and support for audit messages [20]. Part 7 describes an authentication system called User Identity Negotiation [21]. According to the standard, User Identity Negotiation supports a username and password, a Kerberos service ticket, SAML, or a JSON Web Token (JWT). However, the DICOM standard does not require vendors to implement any of these technologies, nor does it require operators to use them. In practice, this means that DICOM systems can be operated without any security measures in place.

2.2.2. HL7. HL7 (Health Level Seven) is the most widely used standard for data transmission in healthcare facilities. The organization responsible for its development, Health Level Seven International, reports that 95% of all healthcare organizations in the US use HL7 [22]. There are currently two versions of HL7 in use, v2 and v3. While HL7v2 was published in 1987, its direct successor, HL7v3, never achieved widespread adoption, mainly due to its complexity [23]. Versions 2 and 3 are fundamentally different and incompatible.

HL7v2 messages are encoded in an ASCII-based text format. A message consists of several segments, each of which consists of several fields. The fields are separated by a pipe. In most cases, data is transmitted using the Minimal Lower Layer Protocol (MLLP) over TCP. HL7v2 has no security features, except for the User Authentication Credential Segment (UAC), introduced in version 2.6. UAC is used for user authentication and supports Kerberos and SAML. The lack of security features makes HL7v2 a vulnerable protocol, and protections must be provided entirely by the operator. HL7v2 interfaces that are exposed to the Internet can therefore be considered an immediate security risk.

2.2.3. FHIR. The FHIR standard, introduced by the HL7 international organization in 2011, aims to combine the strengths of HL7v2 and HL7v3 [24]. Although FHIR is a comparatively new protocol, its usage is steadily increasing. This is partly due to large tech companies, including Amazon, Google, IBM, Microsoft, Oracle, and Salesforce, agreeing to use FHIR to equip the healthcare sector with cloud-enabled technology [25]. The scientific literature is also increasingly focusing on FHIR, which can be interpreted as a further sign of its growing relevance [26].

FHIR is based on modern web technologies and uses JSON and XML for data transmission via HTTPS or HTTP. Furthermore, FHIR describes itself as RESTful and is compatible with Level 2 of the REST Maturity Model [27]. FHIR uses resources modeled as objects in the healthcare system, such as patients, organizations, and medications. The current FHIR version, R5, contains 157 different FHIR resources [28].

The FHIR standard itself does not prescribe any security features. However, FHIR includes a Security and Privacy Module that summarizes security topics for FHIR systems. This includes transport encryption, authorization and access control, authentication, security and privacy audit logging, digital and electronic signatures, and more [29]. Overall, the web-based architecture makes it much easier to secure FHIR using well-known security measures.

3. Honeypot

Previous studies [1]–[6] revealed that a considerable number of DICOM servers exposed patient data, such as X-ray images, to the Internet. However, no studies on publicly available HL7 or FHIR endpoints have been published. Furthermore, it remains unknown if attackers already target these endpoints on a large scale. To close this gap, we developed a low-interaction honeypot exposing HL7, DICOM, and FHIR endpoints. This honeypot pretends to be a healthcare system accessible on the Internet and logs any attempts to use the DICOM, HL7 or FHIR protocols on the port listed in Appendix G, providing insights into the current attack landscape.

We set up our honeypot on an independent server on the Internet, ran it from 1st November 2024 to 1st August 2025, and evaluated the collected logs. The honeypot was hosted by Netcup, a company based in Germany, and used an IP address from AS197540. As shown in Fig. 2, a public DICOM server can be expected to be scanned between 4 and 22 times per day. A total of 3,425 DICOM requests were registered during the analysis period. 87.36 % of these were C-ECHO requests, and a further 12.35 % were C-FIND requests. When analyzing the source IP addresses, we saw automated large-scale scans from platforms such as Shodan or Censys. Moreover, we observed interactions from non-attributable addresses, indicating scans from potentially malicious entities. A total of 1,283 different source IP addresses were identified. A total of 754 (58.77%) source IP addresses scanned our honeypot multiple times, while 529 (41.23%) were detected only once.

Interestingly, despite simulating the behavior of 14 FHIR endpoints and three HL7 services, we did not

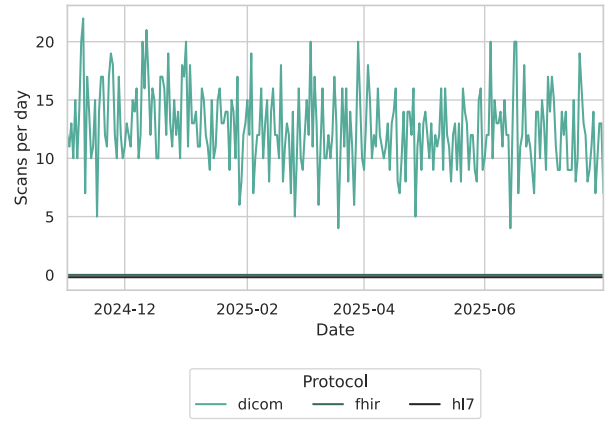


Figure 2: Number of requests registered by the honeypot over a time period of 9 months.

observe any interactions with them. While this does not mean these protocols are generally ignored by attackers, our results indicate that no Internet-wide scans are currently being conducted, either by malicious parties or by researchers.

Our honeypot did not attempt to lure attackers into believing that the host in use belonged to a healthcare facility. The low-interaction honeypot exclusively mimics the endpoints of three healthcare protocols, sending a static, predefined response to requests. There is no special website or messages that could mislead the attacker into believing that this is a real system. Furthermore, the IP address does not indicate that the host is part of a healthcare facility. Despite this limitation, the honeypot is well suited to our intended use of detecting large-scale scans aimed at identifying healthcare protocols.

4. Methodology

4.1. Threat Model

Patient data is highly sensitive and therefore attractive to attackers. Attackers who can access patient data can use it to blackmail patients, healthcare facilities, or sell the data directly on the darknet. Numerous such healthcare data breaches have been reported [30]–[32]. If attackers can not only read but also modify patient data, the risks to patients may increase, e.g., to the point where changes in medication doses threaten patients’ well-being.

We assume a threat model where attackers target publicly accessible healthcare systems that expose sensitive services, such as FHIR, HL7, or DICOM endpoints. Attackers may connect directly to the IP address of a public-facing healthcare host using standard tools, send protocol-compliant requests, and try to overcome authentication measures to extract or manipulate patient data. Furthermore, attackers may choose to perform Meddler in the Middle (MitM) attacks, trying to intercept network traffic and capture sensitive user data.

4.2. Overview

We split up our analysis into three phases: The Scanning phase, the Confirmation phase, and the Security & Privacy

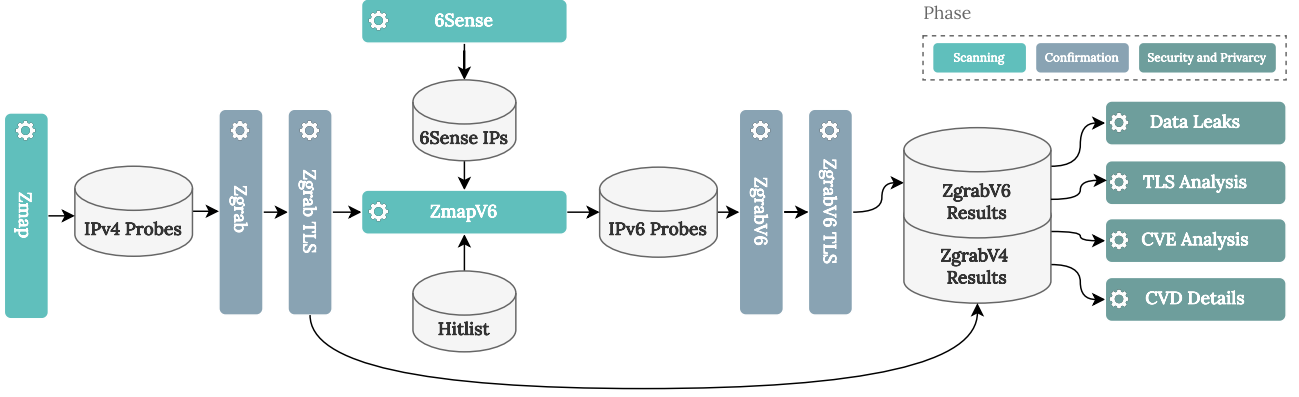


Figure 3: Overview of the IT architecture of the scanning pipeline. The pipeline is run through for all three healthcare protocols.

phase. During the Scanning phase, we scanned public IPv4 and IPv6 addresses on ports associated with healthcare protocols (see Table 7) to identify potential publicly exposed healthcare services. During the Confirmation phase, we exchange protocol handshakes with these systems, ensuring that they serve the expected network protocol. After successfully identifying healthcare systems, we investigated them more thoroughly during the Security & Privacy phase.

However, the Scanning and Confirmation phases do not run in parallel or one after the other. Rather, the two phases overlap. First, an IPv4 scan is started (scanning phase). Once this is complete, the IPv4 confirmation phase for non-TLS and TLS is started automatically. Next, the IPv6 scan (scanning phase) is performed, after which the IPv6 confirmation phase for non-TLS and TLS is started. The final step in the process is the Security & Privacy phase. We depicted the entire scanning process in Fig. 3. The same scan process is run for all three healthcare protocols.

4.3. Scanning phase

4.3.1. IPv4 and IPv6 scanning. For identifying healthcare services at Internet scale, we used ZMap [33] and ZMapv6 [34], network scanners that are commonly used for Internet-wide measurements. While scanning the whole IPv4 address range (/0) using ZMap is straightforward, it is impossible to scan the full IPv6 range due to the vast quantity of IPv6 addresses (2^{128}).

To scan as many systems as possible, we combined two methods to obtain lists of promising IPv6 address ranges. First, we used 6Sense [35], a research project that leverages machine learning to generate and optimize IPv6 address lists for active hosts. We ran 6Sense on a Linux server with 512 GB of memory and two 80 GB Nvidia A100 GPUs, which allowed us, over the course of a week, to generate an address list holding 100 million IPv6 addresses. We combined this address list with the IPv6 addresses from the widely known IPv6 Hitlist [36]–[38], a research project that collects and shares lists of actively communicating IPv6 addresses to facilitate Internet measurements. We removed duplicates arising from combining the two address lists and fed our results into ZMapv6 to perform our scans. Depending on the healthcare protocol, this approach resulted in between 137

and 139 million IPv6 addresses, since a different number of ports were scanned for each protocol. The number of IPv6 addresses ($n=139$ million) is significantly lower than the total number of IPv4 addresses ($n=3.70$ billion non-reserved).

Since we scan both IPv4 and IPv6 hosts during the Scanning phase, and we need to minimize the time between the Scanning phase and the Confirmation phase to minimize the effect of dynamic IP address churn, we first performed scans and confirmations for IPv4 addresses, then for IPv6 addresses. The data collected is based on a single scan per healthcare protocol. The scans took place in October 2025.

4.3.2. Port list. During the Scanning phase, we scanned the Internet for hosts listening on TCP ports that are commonly used by healthcare services. As no comprehensive list of commonly used ports for DICOM, HL7, and FHIR services exists, we distilled one using the following multi-step approach.

Firstly, we analyzed the healthcare protocol standards and collected information on officially registered ports from the Internet Assigned Numbers Authority (IANA). For example, ports 11112, 2762, and 2761 are reserved for DICOM at IANA [39]. Secondly, we investigated which standard ports are used in major software implementations, e.g., by reading the software documentation or directly examining the source code in public Git repositories. We assume that a significant number of administrators do not change preconfigured ports. Thirdly, as a supplementary method for FHIR services, we used public data from Censys.io [40] and Shodan.io [41], both popular online platforms that provide access to regularly conducted Internet scans. Both services allow filtering search results and examining the service responses to HTTP queries. Since FHIR systems may listen on a multitude of ports, we searched their scan databases for the string `application/fhir+`, which is used by most FHIR services as the Content-Type header in HTTP responses. In this way, we obtained a list of actively listening FHIR services and added the most commonly found ports as scan targets.

In total, we collect 31 ports for our scans. Table 8 in the appendix provides an overview of the scanned ports and their origin.

4.4. Confirmation phase

Previous work has shown that administrators, besides using preconfigured ports, regularly choose to run protocols on non-standard ports or on ports that may be reserved for other protocols [42]. We therefore need to verify that services running on common ports indeed run DICOM, HL7, or FHIR [43]. During the Confirmation phase, we connect to the previously identified candidates, send standard-conforming protocol messages to the services, and verify the responses. For this, we developed Zgrab2 [44] modules that send protocol-specific messages and examine the services' responses.

For each service, we tried to establish a connection once with TLS and once without TLS, acquiring the data required for our TLS analysis (see Section 4.5).

4.4.1. DICOM Confirmation. When a DICOM client – a Service Class User (SCU) – initiates communication with a DICOM server – a Service Class Provider (SCP) –, the first step is the negotiation of connection parameters in the form of a handshake. This process is named *Association Negotiation*, and results in coordinated communication parameters between the AEs [19], e.g., format and order of messages.

We use this process to verify the presence of DICOM services; i.e., we initiate DICOM association negotiations with potential DICOM services. Based on the godicom package [45], we developed a ZGrab2 module that contacts the SCP with an association request (A-ASSOCIATE-RQ). We request the usage of the DICOM C-ECHO service, a service that is commonly used to verify application-level communication between AEs. Upon receiving the association request, the SCP evaluates the proposed parameters and sends an A-ASSOCIATE-AC response, including information about acceptance or rejection of the handshake. In case we receive a response, regardless of acceptance status, we successfully identified an active DICOM service instance.

4.4.2. HL7 Confirmation. To identify HL7 systems, we developed a ZGrab2 module that sends an HL7 message over MLLP to the remote system. By ensuring that the HL7 message conforms to the IHE IT Infrastructure (ITI) Technical Framework [46], a common set of components and interactions used by healthcare facilities, we ensured that it can be processed by most HL7 systems.

As HL7 allows the manipulation of patient records, we send an HL7 message type that definitely does not change any patient data: the HL7 Patient Demographics Query (PDQ) message.

To prevent the return of real patient data, we specifically filter for a made up and most likely non-existing patient with the first name *Mr.* and the last name *Spock*. The resulting HL7 message is shown in Fig. 5 in the appendix.

Although a PDQ query may not be supported by all systems, and a search for the patient *Mr. Spock* may not return any results, we can still use this message to confirm the presence of an HL7 service. In either case, the remote system responds with a Message Acknowledgement (MSA), on which we mark the service as confirmed. An MSA contains a field (MSA-1) with an acknowledgement code that can have one of the following values: Appli-

cation Accept (AA), Application Error (AE), Application Reject (AR), Commit Accept (CA), Commit Accept (CA) or Commit Reject (CR) [47]. The acknowledgement codes show how the remote system handled our message.

4.4.3. FHIR Confirmation. The presence of a FHIR *CapabilityStatement* can be used to identify FHIR endpoints. Capability Statements are used to retrieve metadata and provide an overview of the features implemented by a FHIR endpoint. As Capability Statements contain technical information important to clients rather than sensitive information, they can be retrieved without authentication. If an error occurs while retrieving any FHIR resource, the FHIR endpoint returns an *OperationOutcome* error. This error message is also FHIR-specific and can therefore be used to identify an FHIR endpoint. However, an *OperationOutcome* error contains significantly less information about the system than a Capability Statement.

A major challenge in searching for FHIR systems is the freely selectable URLs of FHIR endpoints. A URL for a FHIR endpoint consists of the IP address or the domain name and the FHIR endpoint name, as well as the resource type at the end of the URL, e.g. */metadata*, which is used to query a Capability Statement. A FHIR URL has the following structure: *http://{ip/domain}/{endpoint}/{resource_type}*. From the ZMap scan, we know the IP addresses and the resource type (*/metadata*). However, the *{endpoint}* remains unknown. To find as many FHIR endpoints as possible, we collect the standard endpoints of FHIR applications. We examined several lists of FHIR applications and public FHIR test servers [48], [49] and extracted their endpoints. In total, we identified 13 endpoints using this method. A complete list of the endpoints used can be found in Section E.

Each of these endpoints is queried by our ZGrab FHIR module for each IP address. We also translate IP addresses into possible hostnames, thereby avoiding problems when accessing servers that use virtual hosting. To achieve this, we extract the common name (CN) from the TLS certificates of the web servers, as this method should retrieve the names that best match the virtual host entries. For each virtual host, 13 queries, one per endpoint, need to be sent to the server, leading to a high number of queries per server, which we want to avoid. Taking the information in the Subject Alternative Name (SAN) field into account could provide more addresses. However, this would lead to a significant increase in the number of requests per host. Our approach ensures that virtual hosts can be queried while limiting the number of queries per IP address to 26.

The ZGrab module then searches the requested FHIR URLs for the strings *CapabilityStatement*, *Conformance* (this string is used up to FHIR version DSTU2 in a *CapabilityStatement*), and *OperationOutcome*. If at least one of these strings is present, an FHIR endpoint has been found.

There are also some companies that offer FHIR endpoints as a service for customers or patients. They use a UUID or a complex random string for the *{endpoint}* part of the URL, enabling them to assign each customer their own endpoint. Therefore, it is not feasible to detect

these endpoints with our scans. Nevertheless, to account for FHIR endpoints with arbitrary URLs, we have included an analysis of the Lantern dataset, which is a collection of FHIR endpoints, in Appendix F. This dataset provides a collection of FHIR endpoints from developers of healthcare IT products.

4.5. Security and Privacy phase

During the security and privacy phase, we thoroughly investigated potential data leaks, TLS flaws, and software vulnerabilities across the identified healthcare services. To do so, we enriched our scan results with additional data from Censys.io [50]. This includes server geolocation, abuse information for the disclosure process, and information about additional ports the servers listen on.

4.5.1. Identifying DICOM Data Leaks. While public exposure of a DICOM service does not directly imply a data leak, such a leak occurs as soon as the service provides access to patient data without authentication. Previous studies have shown that for authentication [3], [4], [6], DICOM services often rely solely on the AE-titles transmitted during the Association Negotiation. In these cases, whenever a valid AE-title is recognized by the server, it provides access to patient data. Even more concerning, DICOM services may choose to accept arbitrary AE-titles, which corresponds to the absence of any authentication.

We identify data leaks by attempting to establish an association using an arbitrary AE-title and, upon successful authentication, use the DICOM C-FIND service to test access to patient data. C-FIND requests allow clients to query a remote server for patient information. On success, the server returns the requested patient records with the corresponding status code. Due to its scriptable Python API, we use pynetdicom [51] to perform the described analyses. To ensure that our study meets the highest possible ethical standards, we process as little data as possible when verifying access to patient data. We only request the first available patient record and only evaluate the status code of the response for verification. We do not process or store any further patient data, minimizing the data required for leak verification to the absolute minimum.

Similarly, while brute-forcing AE-titles based on a list of commonly chosen values may certainly be feasible and interesting from a security perspective, we considered this approach problematic for ethical and legal reasons. Therefore, we decided to omit brute-forcing and instead use a side-channel to study chosen AE-titles. Previous work on LDAP servers has indicated that healthcare services may leak AE-titles via LDAP instances running on the same server [52]. Therefore, we scan healthcare servers for LDAP instances running on the same IP address, and evaluate the AE-titles they leak.

4.5.2. Identifying HL7 Data Leaks. Detecting HL7 data leaks is significantly more complex than simply identifying HL7 endpoints. A data leak requires data to be readable. However, HL7 is not primarily designed for reading data. It is much more designed for pushing messages, i.e., writing and updating data records. Nevertheless, it is possible to detect a data leak. To achieve this, we evaluate the response to the PDQ message described in

Section 4.4.2 that we send, even though the PDQ function is not supported by most endpoints.

The received MSA message can be divided into two cases. Either the HL7 endpoint processed our PDQ message, or an error occurred during processing. If the PDQ message was processed, the MSA message will contain the value AA or CA in the MSA-1 field, and the MSA-3 field will contain text that can be selected by the healthcare facility operator. In this case, we assume that we can perform any PDQ query to search for specific patient data, which could result in a data leak. If an error occurs during processing of the PDQ message, however, the MSA-1 field contains the value AE, AR, CA, or CR. Additionally, an error segment will be added to the HL7 message. The ERR-3 field in the error segment contains an error code, while the ERR-8 field contains free text that can be selected by the operator.

The MSA message can also be used to determine whether the HL7 endpoint uses the UAC authentication. If the server supports UAC but authentication information is missing or incorrect, the ERR-7 field must indicate an authentication error [22].

4.5.3. Identifying FHIR Data Leaks. Unlike DICOM and HL7, many FHIR services are intended for patient access and information sharing, and therefore need to be exposed to the Internet. To further explore security and privacy issues, we request multiple resources from the FHIR endpoints. The CapabilityStatement resource contains information about the FHIR version in use, the implementation name and version, and the supported authentication methods.

A FHIR data leak is present when the /Patient resource can be accessed without authentication. However, patient data would be transmitted directly when the /Patient resource is accessed from a service without required authentication. In line with our ethical considerations (see Section 9), we have therefore decided to use the summary function of the FHIR standard [24]. This function can count the number of entries (IDs) in a resource without displaying or transmitting the actual data. The return value is the number of IDs in the database.

To check for an FHIR leak, we query the following URL: `BASE_URL/Patient?_summary=count`. This enables us to detect and quantify data leaks by counting patient IDs. Technically, it is possible to use an authorization interceptor function at application level, as implemented by the HAPI FHIR server [53], to prevent access to all patients while allowing the summary function to count all patients. However, this is not a default configuration and we do not consider this a likely scenario, which is why we assume that patient data can also be retrieved when the summary function is successfully called.

One disadvantage of this approach is that some FHIR software implementations do not support the summary function. Additionally, we analyse the FHIR resource /Organization, which is typically protected by authentication and does not expose any patient data. Furthermore, we analyse HTTP response codes to determine if authentication is required to access FHIR resources.

4.5.4. TLS Evaluation. Secure transport encryption is vital for protecting patient data, especially on Internet-exposed hosts. Previous work has shown that Internet-

facing systems do not always configure TLS securely [54], [55]. Therefore, we analyze the TLS configurations of the healthcare systems we discover. We analyze overall TLS usage, TLS versions and cipher suites, and check for self-signed TLS certificates.

We use ZGrab's TLS logs from the confirmation phase for the TLS analysis. We use the standard TLS configuration for Zgrab. This means that no minimum or maximum TLS versions are specified, and the standard cipher suites from ZCrypto are used [56]. The server's selected cipher suite can be retrieved from the TLS logs. We use information from ciphersuite.info, retrieved via its API, to determine which cipher suites are considered insecure [57].

4.5.5. Vendor and CVE Analysis. During the security and privacy phase, we evaluate the software implementation used by healthcare providers. For FHIR, the /metadata endpoint provides information about the software and its version, as well as the FHIR version, allowing detailed analysis. For DICOM, information from a C-ECHO can be evaluated as it contains details of the software library and version used. However, it is not always possible to draw a definitive conclusion about the DICOM server software from the library used, as many software manufacturers rely on third-party libraries. HL7 is the only protocol that does not offer any possibility to infer the software used directly. In this case, it is only possible to evaluate the HL7 version used, as this is always included in an ACK message.

We use the extracted software information to identify known vulnerabilities in the server implementations, as these often lead to data leaks or other security risks. For this, we match the software information with publicly known vulnerable versions based on the NIST National Vulnerability Database (NVD) API [58]. We use the following procedure to determine the Common Vulnerability Scoring System (CVSS) values from the NVD: First, we attempt to obtain the CVSS NVD value for version 3.x. If this value is not available, we use the value assigned by the CNA for version 3.x as a fallback. For older CVEs, we use the CVSS value for version 2.0 as a fallback if no corresponding value for version 3.x is available.

4.5.6. Global Exposure. To classify data leaks, TLS flaws, and vulnerabilities in healthcare systems more accurately, we match affected hosts' IP addresses to the respective countries. TLS flaws are considered only if there is an insecure TLS configuration. Hosts that do not use TLS are excluded from these statistics. The GeoLite2-Country Database [59] is used to determine the geographical location.

5. Scan Results

5.1. Port Scan

During the scanning phase, we found 224,634,689 hosts responding to a SYN request on one of the ports outlined in Table 7. For DICOM, we identified 18,804,260 potential IPv4 hosts and 129,242 IPv6 hosts. For HL7, we found a total of 35,641,547 IPv4 hosts and 336,836 IPv6 hosts. The most significant number of potential hosts was found for FHIR, with 166,000,704 IPv4 hosts and

3,722,100 IPv6 hosts. The higher values can primarily be explained by the large number of hosts exposing ports 80 and 443 for regular web traffic.

5.2. Healthcare Services at Internet-Scale

5.2.1. Overview. During the confirmation phase, we found all three healthcare protocols on the Internet. The following values refer to the number of endpoints, which consist of an IP address (host) and a port. For FHIR, the endpoint is also included in the URL. This distinction is important because some hosts offer multiple instances simultaneously.

In total, we found 9,141 DICOM endpoints (listening on 8,169 unique hosts). However, a DICOM association only works with 4,562 endpoints, and 4,500 endpoints responded to a C-ECHO request.

Moreover, we found 917 HL7 endpoints (897 unique hosts). 639 endpoints responded with an AR code. 205 endpoints responded with an AA code and 70 others with an AE code.

Finally, we found a 1,477 FHIR endpoints (408 unique hosts) with /metadata infos. 460 of these use a Capability Statement, while 12 provide a Conformance Statement. Furthermore, we found 1,005 endpoints that return an OperationOutcome. An OperationOutcome is displayed when an FHIR endpoint is accessed via an incorrect URL. For example, if the correct FHIR URL is /fhir/metadata, but a GET request is made to baseR4/metadata, an OperationOutcome may occur. Since we query up to 13 endpoints, we often receive an OperationOutcome. For 80 hosts, we only receive an OperationOutcome and no CapabilityStatement or ConformanceStatement. The stated reasons for this behavior range from not supported as a message in the returned resource to HTTP Code 401 unauthorized. Table 1 shows all identified endpoints, including status and TLS usage.

5.2.2. IPv4 vs. IPv6. By far, the majority of identified healthcare services use IPv4 addresses. But a few systems also use IPv6 addresses. We identified a total of 20 DICOM hosts, 3 HL7 hosts, and 1 FHIR host with an IPv6 address. The HL7 and FHIR hosts provide their services exclusively via IPv6 addresses. This evaluation is not possible for DICOM, as we do not have sufficient details about endpoints to clearly identify them across multiple IP addresses.

5.2.3. Intersection of Healthcare Services. As Fig. 4 shows, some systems expose more than one healthcare service to the Internet. In total, there are 483 systems that provide both a DICOM and an HL7 service. This corresponds to 53.96% of all HL7 systems. This observation can be explained by the fact that DICOM applications like Picture Archiving and Communication Systems (PACS), for example, have both DICOM and HL7 interfaces. Only 5 systems were found that expose both DICOM and FHIR services. Manual examination of the 5 systems revealed that, unlike the combination of DICOM and HL7, this is not an application that provides both protocols, but rather several applications running simultaneously on a server. In these cases, a conceivable scenario is that the DICOM data (e.g., patient master data) is processed directly via an

Table 1: Endpoints publicly exposing healthcare services via the Internet.

DICOM				HL7				FHIR			
Status	Plain	TLS	Σ	Status	Plain	TLS	Σ	Status	Plain	TLS	Σ
DICOM Support	8,731	410	9,141	HL7 Support	915	2	917	FHIR Support	852	625	1,477
Association	4,496	66	4,562	MSA AA	204	1	205	CapabilityStatement	314	146	460
C-ECHO Response	4,434	66	4,500	MSA AE	69	1	70	OperationOutcome	535	470	1,005
C-FIND Support	1,899	4	1,903	MSA AR	639	0	639	ConformanceStatement	3	9	12
				MSA CA	0	0	0				
				MSA CE	0	0	0				
				MSA CR	0	0	0				
				Non-compliant	3	0	3				

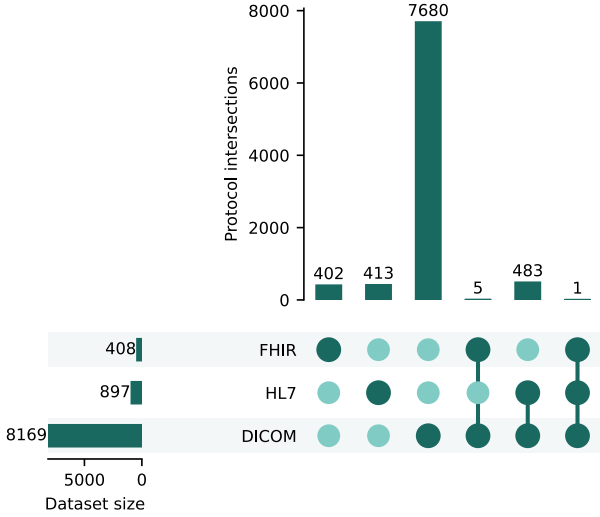


Figure 4: Number of hosts with and without intersection of multiple healthcare protocols.

interface in the FHIR application. Only one host serves all three healthcare protocols. This host runs a test framework for validating IHE-compliant interfaces for healthcare protocols, which supports all three protocols.

6. Security & Privacy Evaluation

6.1. Data Leaks

6.1.1. DICOM Data Leaks. For each confirmed DICOM service, we tried to negotiate an association using the default values for the calling AE-title (*PYNETDICOM*) and the called AE-title (*ANY-SCP*), and we checked support for DICOM C-FIND requests. In total, this led to 1,903 successfully established associations. When querying patient data, our measurements show that in 93.54% of these cases, a successful association is sufficient to access patient data without further access control, resulting in 1,780 DICOM services leaking patient data to arbitrary clients.

In case the association failed, in 3,355 out of 3,777 times, the failure resulted from a rejection of the called AE-title. This means the server will not accept connections from arbitrary clients; instead, it requires them to know the correct server AE-title to connect, which effectively serves as a security/authentication feature. This behavior motivates evaluating leaked AE-titles via LDAP servers. Out of all confirmed DICOM services, 1,702 run in parallel with an LDAP server. Out of these, 170 LDAP

servers allowed us to query AE-titles without requiring authentication, resulting in a leak of the necessary access data. Table 9 in the appendix lists the top 20 AE-titles that we were able to retrieve via the LDAP queries.

6.1.2. HL7 Data Leaks. We did not find any strings in the ERR-7 field that confirm the presence of the UAC authentication feature. This means that none of the HL7 endpoints found (n=917) use a genuine authentication method. In 14 cases, we found indications in the HL7 message that the sending Application or Facility or the receiving Application or Facility is unknown or not authorized. This could suggest a simple way to increase the security of HL7 endpoints, similar to DICOM’s AE-titles.

However, this does not mean that all endpoints except for these 14 HL7 endpoints are affected by data leaks, as most HL7 endpoints do not support data extraction. The evaluation of the MSA segments shows that in 22.36% cases, the HL7 response message contains an AA code. In these cases, the endpoint processed the message without generating an error. In 77.32% of cases, the response contains an AR or AE.

Nevertheless, these figures do not imply that 22.36% percent of all systems are affected by a data leak. 172 HL7 messages with AA codes are empty; it is therefore questionable whether these messages were processed correctly. On the other hand, we also found a message with an AE code and the following text: “query is too vague, query requires either phonenummer, dateofbirth, both firstname and surname, both id and assigningauthorityid parameters”. This indicates that the service accepts HL7 queries, but the search parameters were incorrect.

For further analysis, we divided the HL7 responses into three groups based on the content of the free text fields (MSA-3 or ERR-8): Processed (n=30), Not processed (n=677), and Unknown (n=181). There are a total of 177 HL7 messages with empty text fields in the unknown group. In the 30 cases in which our request was processed, we assume that patient data can be retrieved using a correct HL7 message with an existing patient. In 677 cases, the message could not be processed, meaning that no patient data could be retrieved because the endpoint does not support query messages such as PDQ.

Regarding HL7, it can be said that publicly accessible HL7 endpoints are not at great risk of data leaks, since most do not support data retrieval. The different handling of HL7 messages, which is due to the considerable design freedom granted by the HL7 standard, makes it difficult to assess whether a endpoint would ultimately disclose data if real patient names or IDs were queried. For an attacker

to extract data from an HL7 endpoint, the endpoint would first have to support a query function such as PDQ. The attacker would also need to know how to structure the search query correctly for the endpoint to process it. HL7 queries do not allow the use of wildcards in search queries.

However, manipulating data on HL7 endpoints is a far greater security concern than reading publicly accessible HL7 endpoints. Since we found only 14 endpoints with security measures such as sender and receiver checks, none of which use UAC, and since HL7 is designed for pushing messages, we assume that data could be manipulated on almost all endpoints.

Manipulating the data can have serious consequences for patients. Therefore, every publicly accessible HL7 endpoint must be considered a major security risk.

6.1.3. FHIR Data Leaks. Our data shows that we found 225 FHIR endpoints that responded with an HTTP code 200 when querying the patient resource. Of these 225 endpoints, 242 endpoints contain unprotected patient data.

The 242 unprotected endpoints reveal a total of 2,124,518 patients. However, this patient data might include collisions and test data that do not reflect real patients. Table 2 shows the 20 most common patient data per endpoint.

Another 280 FHIR endpoints returned HTTP code 401. This HTTP code implies that access was denied due to missing credentials. These systems, therefore, most likely use authentication. Another 2 FHIR endpoints returned HTTP code 500, which indicates an error in the web server. 766 FHIR endpoints returned the HTTP code 404, which means that the resource does not exist, and in this case an `OperationOutcome` error is displayed by the FHIR endpoint. This is normal behavior for FHIR endpoints when a FHIR resource is not supported. Of the remaining endpoints, 195 returned other HTTP codes or timed out.

The values for the FHIR resource `/Organization` behave similarly. When requesting this resource, 228 endpoints responded with HTTP code 200, 273 endpoints responded with HTTP code 401, 4 returned code 500, and 778 returned code 404. 186 returned other codes, and the remaining endpoints timed out.

In addition to the HTTP codes, we also evaluated the authentication methods offered by the FHIR endpoint via the `/Metadata` endpoint. Table 3 shows the number of endpoints that advertise specific combinations of three different authentication methods referenced by the queried endpoints. The given information may be flawed, incomplete, or unnecessary for resource access, as endpoints may claim authentication support even if they do not require authentication. Non-conformant metadata may be classified as not advertising any authentication. To provide further insight, we show the number of endpoints that do not require authentication to access patient data. However, an endpoint without authentication might not enable access to the `/Patient` resource if the functionality is not implemented.

6.2. TLS Analysis

The evaluation of TLS handshakes (see Table 4) shows that, while TLS support for healthcare protocols is generally low, it varies by protocol. Only 4.6% of DICOM

Table 2: Top 20 FHIR Endpoints exposing patient data.

Endpoints	Patients
https://x.x.x.x:443/fhir	685,100
http://x.x.x.x:9080/fhir	585,569
https://x.x.x.x:443/baseR4	435,745
http://x.x.x.x:8080/fhir	176,306
http://x.x.x.x:8080/fhir	59,804
http://x.x.x.x:9080	46,658
http://x.x.x.x:80/fhir	30,730
http://x.x.x.x:8082/fhir	18,448
https://x.x.x.x:443/baseR5	17,635
http://x.x.x.x:8090/fhir	12,915
http://x.x.x.x:8080/fhir	10,567
http://x.x.x.x:8080/fhir	9,498
http://x.x.x.x:80/fhir	8,567
http://x.x.x.x:8081/fhir	5,868
http://x.x.x.x:8080/fhir	2,915
https://x.x.x.x:443/baseR5	2,122
https://x.x.x.x:443/baseR4	2,121
https://x.x.x.x:443/baseDstu3	2,115
http://x.x.x.x:80	1,482
http://x.x.x.x:8080/fhir	1,275

Table 3: Authentication methods advertised by FHIR endpoints, categorized by access to patient data.

Method Combination	No Patient Access	Patient Access
none	295 (58.3%)	149 (29.45%)
smart-on-fhir	24 (4.74%)	1 (0.2%)
basic, smart-on-fhir, oauth	13 (2.57%)	1 (0.2%)
oauth	12 (2.37%)	-
basic	8 (1.58%)	1 (0.2%)
smart-on-fhir, oauth	2 (0.4%)	-

hosts support TLS at all. Of those, 21.5% negotiated the outdated version 1.0, while a further 5.6% negotiated the equally outdated version 1.1. Overall, 34.4% of DICOM hosts negotiated a weak or insecure cipher suite, as indicated by [57]. In 23.2% of cases, DICOM hosts presented a self-signed certificate.

TLS support for HL7 is almost non-existent. Only two systems (0.2%) answer to TLS connection attempts at all. These two systems expose a TLS server that is securely configured. Compared to other healthcare protocols, TLS usage is significantly higher for FHIR: In fact, 33.4% of hosts use TLS, all of which support version 1.2, which is still considered secure. Only 4.7% of hosts use a weak or insecure cipher suite regarding [57]. Self-signed certificates are used by only 2.4% of hosts. None of the TLS connections tested for any of the three protocols were implemented via TLS 1.3.

6.3. Vendors, Versions & CVEs

We categorize the identified healthcare systems by vendor and version. Since healthcare protocols vary in functionality, there are differences in the depth of the evaluation.

6.3.1. DICOM Implementations. The analysis of the DICOM software libraries used (see Table 5) shows that the `OFFIS DCMTK` library, in various versions, is used most frequently, in total by 1,122 DICOM endpoints. 454 endpoints indicated the software library `jdt270_6009`, which refers to the Java DICOM Toolkit in version 2.70. The third most frequently used implementation is the `DICOM Image Library` from Osirix with 337 endpoints.

Table 4: Analysis of TLS usage, version, cipher suites and self-signed certificates for healthcare protocol sockets (IP and port combination).

Protocol	TLS Usage			TLS Version		Cipher Suites		Self Signed Certificates
		1.3	1.2	1.1	1.0	Secure	Insecure	
DICOM	410 (4.6%)	0 (0%)	299 (72.9%)	23 (5.6%)	88 (21.5%)	269 (65.6%)	141 (34.4%)	95 (23.2%)
HL7	2 (0.2%)	0 (0%)	2 (100%)	0 (0%)	0 (0%)	2 (100%)	0 (0%)	0 (0%)
FHIR	169 (33.4%)	0 (0%)	169 (100%)	0 (0%)	0 (0%)	161 (95.3%)	8 (4.7%)	4 (2.4%)

Table 5: Top 10 used software products (DICOM and FHIR) and including security vulnerabilities.

DICOM			
Software and Version	Count	CVE Count	Max CVSS
jd1270_6009	454 (23.7%)	0	N/A
OFFIS_DCMTK_369	267 (13.9%)	2	7.8
OFFIS_DCMTK_367	235 (12.3%)	5	7.8
OSIRIX_361	208 (10.9%)	1	1.9
OFFIS_DCMTK_368	161 (8.4%)	7	8.1
OFFIS_DCMTK_366	139 (7.3%)	11	9.8
OSIRIX	129 (6.7%)	N/A	N/A
OFFIS_DCMTK_365	88 (4.6%)	12	9.8
OFFIS_DCMTK_364	71 (3.7%)	12	9.8
OFFIS_DCMTK_361	61 (3.2%)	1	7.2

FHIR			
Software and Version	Count	CVE Count	Max CVSS
Snowstorm X FHIR Server N/A	43 (13.4%)	N/A	N/A
HAPI FHIR Server 8.4.0	28 (8.7%)	0	N/A
HAPI FHIR Server 8.2.0	23 (7.2%)	0	N/A
HAPI FHIR Server 8.0.0	16 (5.0%)	0	N/A
HAPI FHIR Server 7.4.0	15 (4.7%)	0	N/A
HAPI FHIR Server 7.0.2	14 (4.4%)	0	N/A
HAPI FHIR Server 7.6.0	10 (3.1%)	0	N/A
HAPI FHIR Server 6.10.0	9 (2.8%)	0	N/A
HAPI FHIR Server 6.2.2	8 (2.5%)	1	9.8
HAPI FHIR Server 5.1.0	8 (2.5%)	2	9.8

6.3.2. HL7 Versions. Of the 917 HL7 endpoints in our data, a total of 855 used version 2.5.1, which we also used for our PDQ message. The remaining 54 endpoints use versions between 2.2 and 2.8. An HL7 endpoint usually supports multiple versions. When a request is made using a specific version, the response is generally sent in the same version. To verify this behavior, we sent an additional message with version 2.4 to the systems. In over 94% of cases, the HL7 server returned the same version. Endpoints that do not support HL7 version 2.6 or higher do not support UAC authentication.

6.3.3. FHIR Vendors and Versions. FHIR offers the most detailed option for determining the software vendor and version. The data shows that the open-source HAPI FHIR Server, in various versions, is the most widely used FHIR software (16.00%). Our analysis also shows that 348 FHIR endpoints use version 4.0.1 of the FHIR standard. By contrast, 27 endpoints use the latest version, 5.0.0, of the FHIR standard.

6.3.4. CVE Analysis. Several known security vulnerabilities can be identified in the found DICOM and FHIR systems. In total, we discovered 1,373 systems with at least one security vulnerability. Of these, 1,333 DICOM and 40 FHIR systems are affected. 397 DICOM systems use the OFFIS DCMTK Library in a version before 3.6.7 and are therefore affected by the two security vulnerabilities CVE-2022-2119 and CVE-2022-2120, each with a CVSS score of 9.8. Both vulnerabilities allow an attacker

to write DICOM files and perform remote code execution. 40 FHIR systems are affected by the CVE-2024-51132 vulnerability, which also has a CVSS score of 9.8. This vulnerability can be exploited to retrieve sensitive information or execute malicious code.

6.3.5. Global Exposure. Table 6 compares the 20 countries with the most exposed DICOM, HL7, and FHIR hosts. The data is based on unique IP addresses rather than endpoints, as endpoints with the same IP address would otherwise be assigned to the same country multiple times. The analysis reveals clear regional disparities in healthcare protocol security.

The United States has by far the most significant exposure, accounting for over a quarter (26.4%) of all identified hosts, and it shows numerous vulnerabilities across all three protocols, especially in DICOM. Brazil and India follow, each representing approximately 10% of total hosts. Notably, India has a higher number of CVEs per host than Brazil. In contrast, European countries such as France and Germany exhibit a lower total number of exposures but a comparatively higher proportion of data leaks in FHIR and DICOM systems.

7. Responsible Disclosure

To mitigate the identified security risks, we first reached out to a national CERT, with the goal of leveraging an established Coordinated Vulnerability Disclosure procedure. In response, the CERT informed us that it does not consider itself responsible for the disclosure procedure. We therefore carried out the responsible disclosure ourselves: We determined the abuse information for each vulnerable endpoint via Censys.io and reached out to the responsible operators. We instructed large service providers such as hosting providers to forward the information the relevant administrators/organizations. We also attached a short questionnaire to our disclosure emails (see Appendix H). A total of 5,806 hosts were included in the disclosure and sent to 550 different email addresses.

After a 4-week waiting period, we repeated the scans for all three healthcare protocols. For DICOM, we observed that 3,004 DICOM hosts were not publicly accessible anymore. However, we found 2,854 new DICOM hosts, indicating that a large part of identified hosts may change their IP addresses dynamically, e.g., due to ISP settings. Ultimately, we measured a total difference of -150 hosts, which equals to a change of -1.64%.

Similarly, HL7 scans revealed that 265 hosts were no longer present, while 232 new hosts were identified. This represents a reduction of -3.68%. With regard to FHIR, 228 hosts can no longer be found, while 163 new ones have been added. This represents a reduction of -15.08%.

A total of just 26 people responded to the questionnaire. 25 respondents answered 'yes' to Question 1, and

Table 6: The top 20 countries worldwide with the highest number of exposed DICOM, HL7, and FHIR unique hosts, including those affected by data leaks, TLS flaws, and known vulnerabilities.

Region	Hosts	Hosts per 1M Inhab.	DICOM				HL7			FHIR			
			Hosts	Leaks	CVE	TLS Flaws	Hosts	Leaks	TLS Flaws	Hosts	Leaks	CVE	TLS Flaws
US	2377 (26.4%)	6,99	2107 (23.4%)	262 (2.9%)	261 (2.9%)	87 (1.0%)	221 (2.5%)	5 (0.1%)	0	158 (1.8%)	43 (0.5%)	22 (0.2%)	6 (0.1%)
BR	1025 (11.4%)	4,83	981 (10.9%)	28 (0.3%)	110 (1.2%)	0	107 (1.2%)	11 (0.1%)	0	4 (0.0%)	1 (0.0%)	0	0
IN	819 (9.1%)	0,56	764 (8.5%)	35 (0.4%)	217 (2.4%)	0	98 (1.1%)	1 (0.0%)	0	24 (0.3%)	10 (0.1%)	2 (0.0%)	0
CN	310 (3.4%)	0,22	297 (3.3%)	30 (0.3%)	88 (1.0%)	0	9 (0.1%)	0	0	9 (0.1%)	3 (0.0%)	0	0
VN	266 (3.0%)	2,63	256 (2.8%)	2 (0.0%)	29 (0.3%)	0	51 (0.6%)	0	0	2 (0.0%)	0	0	0
FR	262 (2.9%)	3,91	225 (2.5%)	69 (0.8%)	61 (0.7%)	0	33 (0.4%)	0	0	31 (0.3%)	8 (0.1%)	0	0
CA	219 (2.4%)	5,34	157 (1.7%)	35 (0.4%)	17 (0.2%)	1 (0.0%)	54 (0.6%)	2 (0.0%)	0	13 (0.1%)	2 (0.0%)	1 (0.0%)	1 (0.0%)
IR	189 (2.1%)	2,05	189 (2.1%)	2 (0.0%)	18 (0.2%)	22 (0.2%)	0	0	0	0	0	0	0
EG	189 (2.1%)	1,62	180 (2.0%)	0	8 (0.1%)	0	16 (0.2%)	0	0	0	0	0	0
DE	183 (2.0%)	2,18	156 (1.7%)	75 (0.8%)	32 (0.4%)	2 (0.0%)	9 (0.1%)	0	0	23 (0.3%)	10 (0.1%)	6 (0.1%)	0
GB	161 (1.8%)	2,33	133 (1.5%)	58 (0.6%)	37 (0.4%)	1 (0.0%)	10 (0.1%)	1 (0.0%)	0	20 (0.2%)	4 (0.0%)	0	0
CL	140 (1.6%)	7,00	113 (1.3%)	11 (0.1%)	13 (0.1%)	0	37 (0.4%)	0	0	3 (0.0%)	1 (0.0%)	0	0
ZA	131 (1.5%)	2,05	123 (1.4%)	12 (0.1%)	6 (0.1%)	9 (0.1%)	5 (0.1%)	1 (0.0%)	0	3 (0.0%)	1 (0.0%)	0	0
AR	129 (1.4%)	2,80	110 (1.2%)	4 (0.0%)	17 (0.2%)	0	33 (0.4%)	3 (0.0%)	0	2 (0.0%)	1 (0.0%)	0	0
RU	123 (1.4%)	0,85	121 (1.3%)	13 (0.1%)	30 (0.3%)	1 (0.0%)	8 (0.1%)	0	0	4 (0.0%)	0	0	0
CO	122 (1.4%)	2,30	120 (1.3%)	4 (0.0%)	20 (0.2%)	0	16 (0.2%)	0	0	0	0	0	0
MX	118 (1.3%)	0,90	103 (1.1%)	5 (0.1%)	16 (0.2%)	0	26 (0.3%)	0	0	0	0	0	0
ID	115 (1.3%)	0,40	111 (1.2%)	37 (0.4%)	33 (0.4%)	0	9 (0.1%)	0	0	1 (0.0%)	0	0	0
KR	112 (1.2%)	2,15	108 (1.2%)	12 (0.1%)	22 (0.2%)	0	1 (0.0%)	0	0	3 (0.0%)	2 (0.0%)	0	0
NL	102 (1.1%)	5,67	84 (0.9%)	33 (0.4%)	10 (0.1%)	0	7 (0.1%)	0	0	14 (0.2%)	4 (0.0%)	0	0
Total:	8987 (100.0%)	Sum:	8169 (90.9%)	1129 (12.6%)	1320 (14.7%)	141 (1.6%)	897 (10.0%)	27 (0.3%)	0	408 (4.5%)	130 (1.4%)	40 (0.4%)	8 (0.1%)

24 also answered ‘yes’ to Question 2. Therefore, it can be concluded that the systems are intentionally made available on the internet. However, only 4 of 22 respondents stated that they reconfigured the systems accordingly (Question 3). When asked which contact method was best (Question 4), most respondents said that an abuse email address or alternative email address was best. 13 people voluntarily indicated in the free-text field for Question 4 that the system in question was a honeypot.

Overall, we found the disclosure procedure had little impact on reducing the total amount of publicly available, vulnerable systems. The number of systems before and after the procedure changed only minimally, and the low response rate to our questionnaire is further evidence of this.

8. Discussion

Our results show that a large share of publicly exposed healthcare services (via DICOM, HL7, or FHIR) suffers from security flaws. DICOM and HL7 endpoints that expose patient data are usually the result of incorrect network segmentation, as these endpoints should not be reachable via the Internet. Furthermore, our analyses show that encryption is rarely available for the transmission of medical data, and various endpoints suffer from critical security vulnerabilities and missing authentication.

Yet the consequences of such security gaps are not merely technical. Patient safety is the most valuable asset of healthcare facilities, but it may be compromised by inadequate security measures. In some of the cases presented, attackers may be able to manipulate patient data, posing a serious risk to patients.

Some of the security deficiencies we identified may be explained by the special demands on healthcare systems. For example, the complexity of establishing and operating transport encryption may pose a risk to patient treatment. Expired TLS certificates can cause connection establishment to fail, leading to communication loss between medical devices and unpredictable consequences. Against this background, the benefits of deploying *in-house* transport encryption may not outweigh their risks.

However, these *internal* systems should never be accessible via the Internet, and it seems operators might be unaware of this. Our results suggest that operators are having difficulty with network configuration and do not check their own infrastructure for exposure; otherwise, these systems would be identified and the issues resolved. Similarly, it is questionable whether healthcare institutions are aware that they are using software with known vulnerabilities or the risks they are exposing themselves to. Reasons for that may be manifold; however, it is well known that cybersecurity in healthcare has been chronically underfunded, leaving the sector particularly exposed [60]. Additionally, healthcare environments use complex, non-mainstream technologies such as HL7 and DICOM, which may make their security more challenging [61].

As a first step towards securing their environments, healthcare facilities should introduce a strict policy that medical systems should never be connected to the internet, and implement the highest possible regulatory and technical barriers to prevent this. We furthermore propose that healthcare institutions reduce the attack surface as much as possible, particularly by implementing recurring vulnerability scans as a cost-effective, scalable mitigation. In practice, operators can use network scans, security scanners, and audits of authentication methods to detect and remedy all of the security issues we have described. To facilitate such scans, we are making the scanners presented in this paper available as open source.

FHIR is the only healthcare protocol designed to be exposed to the Internet for data exchange between parties. As FHIR is based on modern web technology, well-known security methodologies can be applied. Moreover, FHIR itself defines a special authentication method (SMART-on-FHIR) based on OAuth2. DICOM can, in theory, be deployed securely on the Internet, as it includes relevant security features in Parts 7 and 15 of the standard. However, in practice, these security features are not deployed by healthcare facilities and often not even implemented in software. The most often deployed “security measure” for DICOM, the verification of AE-titles, is not a sufficient authentication method. AE-titles are strings of up to 16 characters intended for identifying medical software or

devices. Often, AE-titles can be obtained via LDAP or via the software documentation, which is usually available online. This makes it very easy to brute force or infer AE-titles. HL7 defines no security features (except for UAC) and should therefore never be made available on the Internet.

8.1. Limitations

Our study has some limitations that affect the results. First, it is worth noting that we only scan from a single server in a single location (Germany). As Wan et al. [62] demonstrated, scanning from a single location can negatively affect results, as not all systems can be reached due to network issues and geo-blocking. In accordance with ethical considerations, our Internet scans are based on an opt-out procedure. We added IP ranges of systems whose operators disagree with the scans to an internal scan block list. It is also possible for operators to block our scan server in their firewalls to prevent our scans. The use of different ports by operators can lead to further uncertainty. This applies particularly to FHIR and HL7, as multiple ports are used for these protocols. Limited time and technical resources make it impossible to scan all ports. It should also be noted that it is not possible to identify all active IPv6 addresses, as previous studies have shown [63]. Even combining several methods does not guarantee that all IPv6 hosts will be found. Therefore, our scanning results provide a lower bound estimate on the number of healthcare services available online.

In addition to network-level limitations, there are also protocol-level limitations. When identifying FHIR systems, we need to know the FHIR URL. However, as already described, the FHIR URL can usually be freely chosen by the operator. Therefore, it is not possible to track down all FHIR endpoints. A FHIR system can also remain undetected if the actual public metadata (CapabilityStatement) cannot be retrieved due to an incorrect implementation of the FHIR system or the use of authentication for metadata access.

Furthermore, only the web server's standard certificate is analysed, and only the CN is read. If the FHIR server can only be accessed via the domain name (i.e. virtual host and Server Name Indication) and does not have a TLS certificate, or if the correct system name is only listed in the Subject Alternative Name field or is not included in the standard certificate, the FHIR endpoint will remain unrecognised. With regard to HL7, we have refrained from searching for HL7v3 systems, as this version is not widely used and, in our opinion, the effort required to do so is disproportionate.

The limitations mentioned above may mean that some systems are not found, and that the number of healthcare systems we identified could be higher.

For ethical reasons, we do not download or review patient data that might be present on identified systems. Therefore, we cannot evaluate which percentage of the found systems are test systems, honeypots, or production systems, and whether they contain real patient data. Even if we could identify test systems, it is unclear whether they contain real patient data. It is therefore not possible to draw a definitive conclusion about the systems found.

9. Ethical Considerations

Handling sensitive patient data must be carried out in strict accordance with ethical principles to avoid harming patients. The same applies to systems that process this data and are directly or indirectly involved in patient treatment.

To ensure compliance with all ethical considerations, we conducted a stakeholder-based ethical analysis and applied the principles of the Menlo Report to our research [64]. At the beginning of our research, we identified the following stakeholders: Patients, Malicious Actors, Healthcare facilities, IT staff and IT managers at healthcare facilities, Society, and Network and platform operators.

Patients may be affected by the research, as their data could potentially be accessed from the Internet without authentication or even manipulated. To protect patient safety, we have taken great care throughout the research process to avoid downloading any real data or manipulating it in any way. We are convinced that our research can help reduce the number of unprotected patient data on the Internet by informing the operators of medical facilities about potential security issues through our disclosure procedure. Our research, therefore, has exclusively positive effects on patients.

Malicious actors could use our research to attack vulnerable systems. However, these attacks are not new, and the findings on vulnerable DICOM systems are well known. The risk of misuse of results for HL7 and FHIR is minimally higher, as no results from large-scale scans have yet been published for these protocols. However, HL7, like DICOM, has been an established protocol for a long time, and its lack of security features is well known. It can therefore be assumed that potential attackers are also aware of this. FHIR is intended for use on the Internet, and the authentication methods of some FHIR servers can be easily supplemented. We therefore believe that our research will raise awareness of security issues among FHIR system operators, thereby improving patient safety. Our findings will only be published after the disclosure process, which further minimizes the likelihood of attacks on the systems. Furthermore, we do not publish any information that could be used to identify the vulnerable systems. Overall, we believe that our research reduces rather than increases the risk of attacks on the systems.

Healthcare facilities are also affected by our findings, as they are responsible for the security of patient data. The companies responsible for the data leaks can be identified via IP addresses, abuse contacts, or other metadata. If this information is published, it could damage the company's image and cause patients to lose trust in the company. We have therefore decided not to publish any information that could be used to identify the Healthcare facilities. Only data necessary for the disclosure process is collected. The data is processed securely and deleted as soon as the disclosure process is complete. We therefore believe that our research does not have negative consequences for healthcare facilities.

IT staff and IT managers at healthcare facilities are listed as separate stakeholders. According to our findings, some healthcare systems have configuration flaws, and some lack security updates. It is the responsibility of IT staff and IT managers to ensure that these problems do not

arise in the first place. Presenting our findings to companies could reveal internal quality issues within their IT departments. This, in turn, could have negative consequences for employees. However, the misconfigurations constitute severe deficits that have a direct negative impact on patient safety. Patient safety is the highest priority objective of a healthcare facility and must therefore be guaranteed with the highest priority. After weighing the interests of patient safety against the negative consequences for individual employees, we believe patient safety outweighs these considerations.

Society is also affected by our research. The publication could lead people to adopt a negative view of healthcare facilities and to lose trust in them, resulting in fewer visits. At the same time, society benefits from our research, as we help make systems safer, protecting potential patients. Compared to all healthcare facilities worldwide, only a very small number have been affected by data leaks. We therefore believe that society as a whole will not lose confidence in healthcare facilities and that the benefits outweigh the disadvantages.

Our global Internet scans also affect network and platform operators who run systems on the Internet. Port scans and other requests originating from our system during our research may affect other systems. To minimize risk, we have implemented all eight best-practice procedures outlined by Hantke et al. for our Internet scans [65].

With regard to the ethical principles of fairness and equity outlined in the Menlo Report, we can state that we have established a global Internet scan that searches exclusively for technical medical protocols. All Internet users are treated equally. The same applies to the largely fully automated evaluation of the results. No stakeholders are given preferred or disadvantaged treatment.

The fourth principle, Respect for Law and Public Interest, is also taken into account. Since we do not download or modify patient data, we act in accordance with the law, and our scans are designed to be transparent, as per Hantke et al. [65]. The host that performs the scans discloses all information via a website.

The procedure described was approved by our IRB before the start of the research.

10. Related work

Related work on healthcare protocols can be divided into two categories: scanning and security vulnerabilities.

10.1. Scanning

Previous studies on publicly exposed health protocols on the Internet have focused exclusively on DICOM. In 2016, Stites et al. [1] conducted an extensive, Internet-wide scan to identify accessible DICOM Systems. They developed a tool called DPing and found 2,774 DICOM systems on the Internet, of which 719 were completely unprotected and could have been used in a DICOM exchange.

In 2018, Beek [2] searched for DICOM data using public search engines such as shodan.io. The investigation identified numerous DICOM systems that had significant vulnerabilities.

In 2019, security researchers from Greenbone [3] conducted a further security analysis of publicly available

DICOM systems on the Internet. They also used public sources such as Shodan.io and Censys.io and identified 2,300 DICOM systems. Of these, 1,700 DICOM systems were protected, meaning that no DICOM data could be downloaded from these systems. The DICOM systems were also enriched with additional information to enable assignment to specific countries. In total, the security researchers were able to retrieve 24.3 million DICOM studies and an estimated 399.5 million individual DICOM images. The security researchers [4] repeated the analysis after 60 days and came to a mixed conclusion. The total number of DICOM studies found rose to 35 million, while in 11 countries, all open DICOM systems from the Internet were removed.

In 2020, Vidal et al. [5] also used shodan.io to search for open DICOM systems, especially in Chile. They identified 47 PACS with 23,775 registered patients on these systems.

Another important contribution was made by Yazdanmehr et al. [6], who also conducted an Internet-wide scan in 2023 to identify DICOM systems. Their results showed that 3,806 DICOM systems exposed over 59 million patient records on the Internet.

In contrast, Klick et al. [66] took a different approach. Rather than searching for specific healthcare protocols, they examined the attack surface of German hospitals. Their methodology involved first identifying the hospitals and then searching for specific services. A total of 89 distinct ports were identified, each running various services, some of which exhibited vulnerabilities. However, the results did not indicate any DICOM, HL7, or FHIR services.

10.2. Security Vulnerabilities

In 2018, Dameff et al. demonstrated how a MitM attack on HL7 could be carried out [67]. They developed a tool to eavesdrop on HL7 messages. The lack of security features in HL7 enabled the researchers to read and even manipulate HL7 messages.

In 2019, Ortiz demonstrated a security vulnerability in the design of DICOM files [68]. It is possible to combine a DICOM file with a PE file. The DICOM file remains completely intact and can be read by appropriate programs. At the same time, the newly created PEDICOM file can be executed directly. By inserting PE files, malware can easily be injected into a DICOM file.

Also in 2019, Mirsky et al. successfully modified the content of a DICOM image [69]. They were able to modify DICOM files in such a way that indications of lung cancer could be removed or injected. The researchers conclude that DICOM security features, such as encryption and digital signatures, are the most effective protective measures against this type of attack.

The above-mentioned findings by Yazdanmehr et al. [6] not only revealed publicly accessible DICOM systems, but also exposed an SQL injection vulnerability. To do this, the SQL payload was integrated into a C-FIND command and executed on the remote system.

11. Conclusion

Using a honeypot, we demonstrated that only publicly accessible DICOM systems have been actively searched

for on the Internet until now. We then conducted a study of the three most essential healthcare protocols — DICOM, HL7, and FHIR — searching the Internet for accessible endpoints. Our measurements of healthcare protocols on the publicly reachable internet are the first to consider the IPv6 address space. In this paper, we present the results of the first study on public HL7 and FHIR systems. Our data shows that there are 917 HL7 endpoints on the Internet, 903 of which do not use any form of authentication. We also found 242 FHIR endpoints that do not use authentication and leak data from a total of 2,124,518 patients. Compared to existing research, we can expand on the results for DICOM by finding a total of 1,780 systems that are leaking data and demonstrating that even systems with AE-titles are less secure than previously assumed.

Additionally, we demonstrate that many healthcare systems either do not use TLS or use insecure configurations of it, and that several systems are affected by critical software vulnerabilities. Overall, our data reveal an alarming state of cybersecurity in healthcare deployments, particularly given the possibility of patient data manipulation. We believe that this study has made an essential contribution to healthcare system security and that research into this area should be intensified.

Acknowledgments

We would like to thank Alexander Miethe for his support in setting up the IPv6 scanning pipeline. We would also like to thank Censys for providing us with a Researcher account. We thank the anonymous reviewers for their great feedback on the paper and our shepherd for supporting us in preparing the current version.

This research work was supported by the National Research Center for Applied Cybersecurity ATHENE. This research was also supported by the Graduate School for Applied Research in North Rhine-Westphalia (Graduate School NRW).

The FHIR ZGrab module and several Python scripts for the scan pipeline and data analysis were developed in collaboration with the AI models Claude 4.5 and GPT 5.

References

- [1] M. Stites and O. S. Panykh, "How secure is your radiology department? mapping digital radiology adoption and security worldwide," *American Journal of Roentgenology*, vol. 206, no. 4, pp. 797–804, 2016, pMID: 26934387. [Online]. Available: <https://doi.org/10.2214/AJR.15.15283>
- [2] C. Beek. (2018) McAfee researchers find poor security exposes medical data to cybercriminals. Accessed 2025-05-14. [Online]. Available: <https://www.mcafee.com/blogs/other-blogs/mcafee-labs/mcafee-researchers-find-poor-security-exposes-medical-data-to-cybercriminals/>
- [3] G. N. GmbH. (2019) Sicherheitsbericht ungeschützte patientendaten im internet. Accessed 2025-05-14. [Online]. Available: <https://www.greenbone.net/wp-content/uploads/Ungeschuetzte-Patientendaten-im-Internet.pdf>
- [4] —. (2019) Information security report unprotected patient data in the internet – a review 60 days later or the good, the bad, and the ugly. Accessed 2025-05-14. [Online]. Available: https://www.greenbone.net/wp-content/uploads/Greenbone_Security_Report_Unprotected_Patient_Data_a_Review.pdf
- [5] D. C. Vidal and C. B. Huidobro, "Cybersecurity analysis on pacs-dicom servers in chile," in *Telematics and Computing*, M. F. Mata-Rivera, R. Zagal-Flores, and C. Barria-Huidobro, Eds. Springer International Publishing, 2020, pp. 215–224.
- [6] S. Yazdanmehr and I. Akkulak. (2023) Millions of patient records at risk: The perils of legacy protocols. Accessed 2025-05-14. [Online]. Available: <https://www.blackhat.com/eu-23/briefings/schedule/#millions-of-patient-records-at-risk-the-perils-of-legacy-protocols-34188>
- [7] Institute of Medicine, *The Health of Lesbian, Gay, Bisexual, and Transgender People: Building a Foundation for Better Understanding*. The National Academies Press, 2011. [Online]. Available: <https://nap.nationalacademies.org/catalog/13128/the-health-of-lesbian-gay-bisexual-and-transgender-people-building>
- [8] A. Torab-Miandoab, T. Samad-Soltani, A. Jodati, and P. Rezaei-Hachesu, "Interoperability of heterogeneous health information systems: a systematic literature review," *BMC Medical Informatics and Decision Making*, vol. 23, no. 1, p. 18, 2023. [Online]. Available: <https://doi.org/10.1186/s12911-023-02115-5>
- [9] I. T. I. Council. (2018) Tech industry looks to improve healthcare through cloud technology. Accessed 2025-08-16. [Online]. Available: <https://www.itic.org/news-events/news-releases/tech-industry-looks-to-improve-healthcare-through-cloud-technology>
- [10] A. Inc. (2025) Tech industry looks to improve healthcare through cloud technology. Accessed 2025-08-16. [Online]. Available: <https://developer.apple.com/documentation/healthkit/accessing-health-records>
- [11] G. J. M. MD. (2018) Google cloud for healthcare: new apis, customers, partners and security updates. Accessed 2025-08-16. [Online]. Available: <https://blog.google/products/google-cloud/google-cloud-healthcare-new-apis-customers-partners-and-security-updates/>
- [12] L. Kolovou, M. Vatousi, D. Lymperopoulos, and M. Koukias, "Advanced radiology information system," in *2005 IEEE Engineering in Medicine and Biology 27th Annual Conference*, 2005, pp. 5457–5461.
- [13] J. L. Sepulveda and D. S. Young, "The ideal laboratory information system," *Archives of Pathology & Laboratory Medicine*, vol. 137, no. 8, pp. 1129–1140, 08 2013. [Online]. Available: <https://doi.org/10.5858/arpa.2012-0362-RA>
- [14] Y. Xu, D. Sauquet, E. Zapletal, D. Lemaitre, and P. Degoulet, "Integration of medical applications: the 'mediator service' of the synex platform," *International Journal of Medical Informatics*, vol. 58–59, pp. 157–166, 2000. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S1386505600000848>
- [15] A. Torab-Miandoab, T. Samad-Soltani, A. Jodati, and P. Rezaei-Hachesu, "Interoperability of heterogeneous health information systems: a systematic literature review," *BMC Medical Informatics and Decision Making*, vol. 23, no. 1, p. 18, 2023. [Online]. Available: <https://doi.org/10.1186/s12911-023-02115-5>
- [16] H. international and firely. (2024) 2024 state of fhir survey results. Accessed 2025-04-03. [Online]. Available: https://interop.esante.gouv.fr/ig/doctrine/2024%20StateofFHIRSurveyResults_final.pdf
- [17] M. Europe. (2021) Interoperability standards in digital health: A white paper from the medical technology industry. Accessed 2025-04-03. [Online]. Available: https://www.medtech-europe.org/wp-content/uploads/2021/10/mte_interoperability_digital_health_white-paper_06oct21.pdf
- [18] M. I. T. A. (MITA). (2021) About dicom: Overview. Accessed 2025-04-04. [Online]. Available: <https://www.dicomstandard.org/about>
- [19] National Electrical Manufacturers Association (NEMA). (2025) Dicom ps3.8 2025c - network communication support for message exchange. Accessed 2025-04-04. [Online]. Available: <https://dicom.nema.org/medical/dicom/current/output/pdf/part08.pdf>
- [20] N. E. M. A. (NEMA). (2025) Dicom ps3.15 2025b - security and system management profiles. Accessed 2025-04-04. [Online]. Available: <https://dicom.nema.org/medical/dicom/current/output/pdf/part15.pdf>

- [21] —. (2025) Dicom ps3.7 2025b - message exchange. Accessed 2025-04-04. [Online]. Available: <https://dicom.nema.org/medical/dicom/current/output/pdf/part07.pdf>
- [22] H. L. S. International. (2019) Hl7 messaging standard version 2.9. Accessed 2025-04-03. [Online]. Available: https://www.hl7.org/implement/standards/product_brief.cfm?product_id=516
- [23] D. Bender and K. Sartipi, "Hl7 fhir: An agile and restful approach to healthcare information exchange," in *Proceedings of the 26th IEEE International Symposium on Computer-Based Medical Systems*, 2013, pp. 326–331.
- [24] Health Level Seven International. (2023) Search. Accessed 2025-10-27. [Online]. Available: <https://www.hl7.org/fhir/search.html#summary>
- [25] I. T. I. Council. (2018) Tech industry looks to improve healthcare through cloud technology. Accessed 2025-04-07. [Online]. Available: <https://www.itic.org/news-events/news-releases/tech-industry-looks-to-improve-healthcare-through-cloud-technology>
- [26] M. Lehne, S. Luijten, P. Imbusch, and S. Thun, "The use of fhir in digital health – a review of the scientific literature," in *German Medical Data Sciences: Shaping Change – Creative Solutions for Innovative Medicine*, vol. 267, 2019, pp. 52 – 58.
- [27] Health Level Seven International. (2023) Restful api. Accessed 2025-04-08. [Online]. Available: <https://www.hl7.org/fhir/http.html>
- [28] —. (2023) Resource index. Accessed 2025-04-08. [Online]. Available: <https://hl7.org/fhir/resourcelist.html>
- [29] —. (2023) Fhir security. Accessed 2025-04-08. [Online]. Available: <https://hl7.org/fhir/security.html>
- [30] S. Alder. (2025) Change healthcare increases ransomware victim count to 192.7 million individuals. Accessed 2025-09-04. [Online]. Available: <https://www.hipaajournal.com/change-healthcare-responder-to-cyberattack/>
- [31] Q. Government. (2024) Medibank private cyber incident. Accessed 2025-09-04. [Online]. Available: <https://www.qld.gov.au/community/your-home-community/cyber-security/cyber-security-for-queenslanders/case-studies/medibank-private-cyber-incident>
- [32] D. Ralston. (2021) They told their therapists everything. hackers leaked it all. Accessed 2025-09-04. [Online]. Available: <https://www.wired.com/story/vastaamo-psychotherapy-patients-hack-data-breach/>
- [33] Z. Durumeric, E. Wustrow, and J. A. Halderman, "ZMap: Fast internet-wide scanning and its security applications," in *22nd USENIX Security Symposium*, 2013.
- [34] O. Gasser. (2025) tumi8 / zmap. Accessed 2025-02-12. [Online]. Available: <https://github.com/tumi8/zmap>
- [35] G. Williams, M. Erdemir, A. Hsu, S. Bhat, A. Bhaskar, F. Li, and P. Pearce, "6sense: Internet-Wide IPv6 scanning and its security applications," in *33rd USENIX Security Symposium (USENIX Security 24)*. USENIX Association, August 2024, pp. 2281–2298. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity24/presentation/williams>
- [36] O. Gasser, Q. Scheitle, P. Foremski, Q. Lone, M. Korczynski, S. D. Strowes, L. Hendriks, and G. Carle, "Clusters in the expanse: Understanding and unbiasing ipv6 hitlists," in *Proceedings of the 2018 Internet Measurement Conference*. ACM, 2018.
- [37] J. Zirngibl, L. Steger, P. Sattler, O. Gasser, and G. Carle, "Rusty clusters? dusting an ipv6 research foundation," in *Proceedings of the 2022 Internet Measurement Conference*. ACM, 2022.
- [38] L. Steger, L. Kuang, J. Zirngibl, G. Carle, and O. Gasser, "Target acquired? evaluating target generation algorithms for ipv6," in *Proceedings of the Network Traffic Measurement and Analysis Conference (TMA)*, June 2023.
- [39] I. A. N. Authority. (2025) Service name and transport protocol port number registry. Accessed 2025-04-14. [Online]. Available: <https://www.iana.org/assignments/service-names-port-numbers/service-names-port-numbers.xhtml>
- [40] censys.com. (2025) censys. Accessed 2025-10-29. [Online]. Available: <https://search.censys.io>
- [41] shodan.io. (2025) Search engine for the internet of everything. Accessed 2025-10-29. [Online]. Available: <https://www.shodan.io>
- [42] L. Izhikevich, R. Teixeira, and Z. Durumeric, "LZR: Identifying unexpected internet services," in *30th USENIX Security Symposium (USENIX Security 21)*. USENIX Association, August 2021, pp. 3111–3128. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity21/presentation/izhikevich>
- [43] P. Sattler, J. Zirngibl, M. Jonker, O. Gasser, G. Carle, and R. Holz, "Packed to the brim: Investigating the impact of highly responsive prefixes on internet-wide measurement campaigns," *Proc. ACM Netw.*, vol. 1, no. CoNEXT3, November 2023. [Online]. Available: <https://doi.org/10.1145/3629146>
- [44] Z. Durumeric and D. Adrian. (2025) Zgrab2. Accessed 2025-02-12. [Online]. Available: <https://github.com/zmap/zgrab2>
- [45] apaladiychuk. (2025) go-dicom. Accessed 2025-10-25. [Online]. Available: <https://github.com/apaladiychuk/go-dicom>
- [46] I. International. (2023) The it infrastructure (iti) technical framework, volume 1 revision 20.0. Accessed 2025-05-09. [Online]. Available: <https://profiles.ihe.net/ITI/TF/Volume1/ch-8.html>
- [47] H. L. S. International, "Hl7 messaging standard version 2.9 chapter 2c control vocabulary," 2019, access via <https://www.hl7.org> (Accessed 2025-06-10, only with registration).
- [48] D. Devitt. (2024) 30 fhir server providers. Accessed 2025-08-07. [Online]. Available: <https://darrendevitt.com/13-fhir-server-providers/>
- [49] L. McKenzie. (2025) Public test servers. Accessed 2025-08-07. [Online]. Available: <https://confluence.hl7.org/spaces/FHIR/pages/35718859/Public+Test+Servers>
- [50] Z. Durumeric, D. Adrian, A. Mirian, M. Bailey, and J. A. Halderman, "A search engine backed by Internet-wide scanning," in *22nd ACM Conference on Computer and Communications Security*, October 2015.
- [51] pydicom contributors. pynetdicom: A python implementation of the dicom networking protocol. [Online]. Available: <https://doi.org/10.5281/zenodo.2535991>
- [52] J. Kaspereit, G. Öndarö, G. L. Cesar, S. Ebbers, F. Ising, C. Saatjohann, M. Jonker, R. Holz, and S. Schinzel, "LandDscAPE: Exploring LDAP weaknesses and data leaks at internet scale," in *33rd USENIX Security Symposium (USENIX Security 24)*. USENIX Association, August 2024, pp. 1225–1242. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity24/presentation/kaspereit>
- [53] H. FHIR. (2025) Authorization interceptor. Accessed 2025-11-19. [Online]. Available: https://hapifhir.io/hapi-fhir/docs/securityauthorization_interceptor.html#authorizing-read-operations
- [54] R. Holz, J. Amann, O. Mehani, M. Wachs, and M. Ali Kaafar, "Tls in the wild: An internet-wide analysis of tls-based protocols for electronic communication," in *Proceedings 2016 Network and Distributed System Security Symposium*, ser. NDSS 2016. Internet Society, 2016. [Online]. Available: <http://dx.doi.org/10.14722/ndss.2016.23055>
- [55] Q. Hu, M. R. Asghar, and N. Brownlee, "A large-scale analysis of https deployments: Challenges, solutions, and recommendations," *Journal of Computer Security*, vol. 29, no. 1, pp. 25–50, 2021. [Online]. Available: <https://doi.org/10.3233/JCS-200070>
- [56] ElliotCubit. (2025) zcrypto. Accessed 2025-10-29. [Online]. Available: <https://github.com/zmap/zcrypto>
- [57] H. C. Rudolph and N. Grundmann. (2024) Tls ciphersuite search. Accessed 2025-10-13. [Online]. Available: <https://ciphersuite.info/>
- [58] N. I. of Standards and Technology. (2025) National vulnerability database. Accessed 2025-07-03. [Online]. Available: <https://nvd.nist.gov/developers/vulnerabilities>
- [59] bandoche and P3TERX. (2024) Geolite.mmdb. Accessed 2025-11-19. [Online]. Available: <https://github.com/P3TERX/GeoLite>

- [60] A. J. Cartwright, "The elephant in the room: cybersecurity in healthcare," *Journal of Clinical Monitoring and Computing*, vol. 37, no. 5, pp. 1123–1132, Oct 2023. [Online]. Available: <https://doi.org/10.1007/s10877-023-01013-5>
- [61] M. S. Jalali and J. P. Kaiser, "Cybersecurity in hospitals: A systematic, organizational perspective," *J Med Internet Res*, vol. 20, no. 5, p. e10059, May 2018. [Online]. Available: <http://www.jmir.org/2018/5/e10059/>
- [62] G. Wan, L. Izhikevich, D. Adrian, K. Yoshioka, R. Holz, C. Rossow, and Z. Durumeric, "On the origin of scanning: The impact of location on internet-wide scans," in *Proceedings of the ACM Internet Measurement Conference*, ser. IMC '20. Association for Computing Machinery, 2020, p. 662–679. [Online]. Available: <https://doi.org/10.1145/3419394.3424214>
- [63] I. Egloff, R. Hiesgen, M. Koch, T. C. Schmidt, and M. Wählisch, "A detailed measurement view on ipv6 scanners and their adaption to bgp signals," *Proc. ACM Netw.*, vol. 3, no. CoNEXT3, September 2025. [Online]. Available: <https://doi.org/10.1145/3749215>
- [64] U.S. Department of Homeland Security, "The Menlo Report: Ethical principles guiding information and communication technology research," U.S. Department of Homeland Security, Science and Technology, Cyber Security Division, Tech. Rep., aug 2012, accessed 2025-07-22. [Online]. Available: https://www.dhs.gov/sites/default/files/publications/CSD-MenloPrinciplesCORE-20120803_1.pdf
- [65] F. Hantke, S. Roth, R. Mrowczynski, C. Utz, and B. Stock, "Where Are the Red Lines? Towards Ethical Server-Side Scans in Security and Privacy Research," in *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE Computer Society, May 2024, pp. 4405–4423. [Online]. Available: <https://doi.ieeecomputersociety.org/10.1109/SP54263.2024.00104>
- [66] J. Klick, R. Koch, and T. Brandstetter, "Epidemic? the attack surface of german hospitals during the covid-19 pandemic," in *2021 13th International Conference on Cyber Conflict (CyCon)*, 2021, pp. 73–94.
- [67] C. Dameff, M. Bland, K. Levchenko, and J. Tully. (2018) Pestilential protocol: How insecure hl7 messages threaten patient lives. Accessed 2025-06-12. [Online]. Available: <https://i.blackhat.com/us-18/Thu-August-9/us-18-Dameff-Pestilential-Protocol-How-Unsecure-HL7-Messages-Threaten-Patient-Lives-wp.pdf>
- [68] M. P. Ortiz. (2019) Attacking digital imaging and communication in medicine (dicom) file format standard. Accessed 2025-09-16. [Online]. Available: [https://github.com/d00rt/pedicom/blob/master/doc/Attacking_Digital_Imaging_and_Communication_in_Medicine_\(DICOM\)_file_format_standard_-_Markel_Picado_Ortiz_\(d00rt\).pdf](https://github.com/d00rt/pedicom/blob/master/doc/Attacking_Digital_Imaging_and_Communication_in_Medicine_(DICOM)_file_format_standard_-_Markel_Picado_Ortiz_(d00rt).pdf)
- [69] Y. Mirsky, T. Mahler, I. Shelef, and Y. Elovici, "CT-GAN: Malicious tampering of 3d medical imagery using deep learning," in *28th USENIX Security Symposium (USENIX Security 19)*. USENIX Association, August 2019, pp. 461–478. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity19/presentation/mirsky>
- [70] E. Chan. (2015) The beginner's guide to orthanc. Accessed 2025-11-15. [Online]. Available: <https://www.orthanc-server.com/resources/2015-02-09-emsy-tutorial/index.html>
- [71] V. H. I. GmbH. (2023) Conformance statement version 5.5 dicom conformance statement. Accessed 2025-11-15. [Online]. Available: https://www.visus.com/fileadmin/content/pictures/Downloads/Kommunikationsstandards/conformancstatement_dicom_en.pdf
- [72] K. M. H. K.K. (unknown) tegration and hl7 specification guide for symmetry-pacs. Accessed 2025-11-15. [Online]. Available: https://2020imaging.net/support/PDF/HL7/500-000107A_Integration_and_HL7_Specification_Guide_for_Symmetry.pdf
- [73] axaris software systeme GmbH. (2012) Hl7 – importschnittstelle ardis2. Accessed 2025-11-15. [Online]. Available: <https://www.axaris.de/wp-content/uploads/2016/07/ARDIS2-HL7-Schnittstellenbeschreibung.pdf>
- [74] S. LTD. (2025) Sante worklist server. Accessed 2025-11-15. [Online]. Available: <https://santesoft.com/win/sante-worklist-server/sante-worklist-server-qsg.pdf>
- [75] H. I. LTD. (2009) Configuring the hl7 listener service. Accessed 2025-11-15. [Online]. Available: <https://hermetechzn.com/documentation/listener/index.html?configuringyoursystem.htm>
- [76] N. M. LLC. (2025) Listener settings. Accessed 2025-11-15. [Online]. Available: <https://docs.nextgen.com/en-US/mirthc2ae-connect-by-nextgen-healthcare-user-guide-3273569/listener-setting-s-14129>
- [77] C. S.A. (unknown) Charruapacs – advanced edition. Accessed 2025-11-15. [Online]. Available: https://charruasoft.com/products/manuals/charruapacs_adv.pdf
- [78] A. Health. (2015) Dicom grid l7 guide. Accessed 2025-11-15. [Online]. Available: https://cdn2.hubspot.net/hubfs/353966/DG_HL7_Guide.pdf?t=1459191623401
- [79] H. Soup. (unknown) Introduction to hl7 soup. Accessed 2025-11-15. [Online]. Available: <https://www.hl7soup.com/HL7TutorialIntroductionToHL7Soup.html>
- [80] M. Farooqi, P. Werner, and R. Passas. (2025) hapi-fhir-jpaserver-starter. Accessed 2025-11-15. [Online]. Available: <https://github.com/hapifhir/hapi-fhir-jpaserver-starter>
- [81] Lantern. (2025) About lantern. Accessed 2026-03-16. [Online]. Available: https://lantern.healthit.gov/?tab=about_tab
- [82] M. Mayer, E. Michaud, B. Mathiowetz, and P. Konka. (2025) Project lantern data sources and linking mechanisms. Accessed 2026-03-16. [Online]. Available: https://lantern.healthit.gov/Lantern_Data_Sources_And_Algorithms.pdf

Appendix

A. Data Availability & Open Science

The source code for the honeypot, Zgrab (including the modules for DICOM, HL7 and FHIR), the pipeline running scripts, and the TLS and CVE analysis scripts are published on GitHub (<https://github.com/FHMS-ITS/Healthcare-Scanning>) under an open-source licence.

For ethical reasons, we will not publish any data we have generated on healthcare endpoints, as this information contains details of vulnerable systems that could be exploited by malicious actors.

B. Healthcare Ports and Scan Results

The ports used by healthcare protocols are important for the results of Internet scans. Although there are specified ports for HL7 and DICOM, some manufacturers or operators deviate from these specifications. This is often unavoidable, especially with HL7, as each HL7 listener and sender requires its own port and medical integration engines often have multiple HL7 listeners and senders.

The ports are then often assigned arbitrarily by the operators. To identify the ports, we therefore used various sources, which we present in Table 8. The scan results with the number of responsive IP addresses per port can be seen in Table 7.

Table 8: List of all identified healthcare ports, including their origin.

Port	Protocol	Origin
104	DICOM	IANA Registration
2761	DICOM	IANA Registration
2762	DICOM	IANA Registration
4242	DICOM	Default Orthanc Port [70]
4498	DICOM	Default JIVEX Port [71]
11112	DICOM	IANA Registration
1337	HL7	Default Symmetry PACS Port [72]
2020	HL7	Default ARDIS2 Port [73]
2575	HL7	IANA Registration
3001	HL7	Default Sante Worklist Server Port [74]
6660	HL7	Default Hermitech HL7 Port [75]
6661	HL7	Default MirthConnect Port [76]
6667	HL7	Also frequently used by MirthConnect
6668	HL7	Also frequently used by MirthConnect
8100	HL7	Default CharruaPACS Port [77]
12000	HL7	Default HL7 DICOM Grid Port [78]
22222	HL7	Default HL7 Soup Port [79]
80	FHIR	Default HTTP Port
443	FHIR	Default HTTPS Port
3000	FHIR	Censys & Shodan
8000	FHIR	Censys & Shodan
8080	FHIR	Default HAPI FHIR Port [80]
8081	FHIR	Censys & Shodan
8082	FHIR	Censys & Shodan
8083	FHIR	Censys & Shodan
8085	FHIR	Censys & Shodan
8089	FHIR	Censys & Shodan
8090	FHIR	Censys & Shodan
8888	FHIR	Censys & Shodan
9000	FHIR	Censys & Shodan
9080	FHIR	Censys & Shodan

C. AE-Titles

Some DICOM applications use their own internal Lightweight Directory Access Protocol (LDAP) to store configuration information. This includes the AE-titles used. The LDAP systems that we were able to query

without authentication contain multiple AE-titles. The 20 most common AE titles are listed in Table 9. It seems that open LDAP systems without authentication also contain configuration errors similar to those found in the public DICOM endpoint.

Table 9: Top 20 most frequently leaked DICOM AE-titles.

Rank	AE-Title	Count
1	DCM4CHEE	972
2	IOCM_REGULAR_USE	562
3	AS_RECEIVED	544
4	IOCM_QUALITY	544
5	IOCM_WRONG_MWL	544
6	IOCM_PAT_SAFETY	544
7	IOCM_EXPIRED	542
8	WORKLIST	236
9	STORESCP	45
10	GOMEDICAL	40
11	ARTEM	32
12	AUTANA	19
13	VIEWMED	18
14	NOVAPACS	18
15	GOTELEMEDICINA	12
16	SCHEDULEDSTATION	10
17	PACS2	10
18	ARC1	9
19	CM_QUILICURA	9
20	XMED	9

D. HL7 Message

An HL7 message usually consists of several segments. A label is used at the beginning of each segment. In Figure 5, all segment titles are highlighted in color. Typically, each HL7 message begins with the Message Header Segment (MSH). The MSH segment is used to transmit metadata for processing a message.

Depending on the type, an HL7 message can consist of several segments. Each segment in turn consists of several fields. The individual fields are separated by the | character. The message we use is a Patient Demographics Query (PDQ), which is defined by the Query Parameter Definition (QPD) segment. In an HL7 message, the character ^ is used to separate multiple components within a field, for example to specify first and last names.

```
MSH|^~&|RESEARCHSCANNER|RESEARCHHOST|
RECEIVER_APP|RECEIVER_FAC|20250709211557||QBP^Q22^QBP_Q21|
QID1234|P|2.5.1
QPD|IHE PDQ Query|QRY123|@PID.5^SPOCK^MR^^~@PID.8^M
RCP|I
```

Figure 5: HL7 Message send by the HL7 Zgrab module

E. FHIR Endpoints

We use the endpoints shown in Table 10 to identify FHIR endpoints. Some of the endpoints contain names that depend on the FHIR version. The endpoint can therefore be used to directly identify the FHIR version used. The FHIR standard defines standard levels for the different versions. A FHIR version with the designation Normative is considered an ANSI-approved standard. The designation Trail Use is used for versions that have already been

Table 7: Number of responsive IP addresses broken down by port and IP version.

DICOM			HL7			FHIR		
Port	IPv4	IPv6	Port	IPv4	IPv6	Port	IPv4	IPv6
104	2,953,413	7,313	1337	3,912,462	48,196	80	47,908,945	1,395,729
2761	3,170,334	31,166	2020	3,306,034	48,807	443	43,612,554	1,254,725
2762	3,228,247	33,173	2575	3,137,846	31,951	3000	4,415,112	63,786
4242	3,070,276	9,048	3001	3,575,120	53,230	8000	7,386,535	69,548
4498	3,247,198	34,073	6660	2,877,805	7,359	8080	9,316,742	141,843
11112	3,134,792	14,469	6661	3,056,364	34,739	8081	5,523,293	73,937
			6667	3,039,097	8,400	8082	4,466,124	57,336
			6668	2,887,471	7,640	8083	3,848,766	57,677
			8100	3,467,155	52,821	8085	9,504,375	57,904
			12000	3,299,463	34,961	8089	9,895,522	328,999
			22222	3,082,730	8,732	8090	3,979,744	50,395
						8888	5,057,571	66,988
						9000	6,625,607	54,971
						9080	4,459,814	48,262
	18,804,260	129,242		35,641,547	336,836		166,000,704	3,722,100
Total	18,933,502			35,978,383			169,722,804	

extensively tested and can also be used for productive operation. The designation Draft is used for versions that have not yet been sufficiently tested and should not be used productively.

Table 10: The FHIR endpoints we use for identifying FHIR services, including background information on the versions used.

Endpoint	Version	Standard Level
/metadata	Version-independent	
/fhir/metadata	Version-independent	
/baseR2/metadata	1.0 (R2)	Draft Standard for Trial Use 2
/baseR3/metadata	2.0 (R3)	Standard for Trial Use 3
/baseR4/metadata	4.0 (R4)	Normative
/baseR5/metadata	5.0 (R5)	Standard for Trial Use
/fhir-server/api/v4/metadata	Version-independent	
/r5/metadata	5.0 (R5)	Standard for Trial Use 4
/r4/metadata	4.0 (R4)	Normative
/r3/metadata	2.0 (R3)	Standard for Trial Use 3
/r2/metadata	1.0 (R2)	Draft Standard for Trial Use 2
/baseDstu2/metadata	1.0 (R2)	Draft Standard for Trial Use 2
/baseDstu3/metadata	2.0 (R3)	Standard for Trial Use 3

F. Lantern Dataset Analysis

Lantern [81] is an open-source project designed to monitor and analyse specific FHIR endpoints. It uses public lists compiled by US health IT system developers as its data source. These lists are primarily sourced from the Certified Health IT Product List (CHPL) database [82]. Lantern provides an API that allows users to download all its listed endpoints. Our analysis and comparison of Lantern’s data with our internet scan data is based on the data available as of 12 February 2026. According to the providers’ own figures, the Lantern dataset comprises around 79,000 FHIR endpoints. However, we could only analyse 51,443 of these, as the remaining endpoints were not reachable.

The 51,443 FHIR endpoints that we analysed are spread across just 1,464 unique hostnames. Of these endpoints, 45,358 contain arbitrary values in the {endpoint} section of the URL, so they remain undetected by scans. Similarly, some endpoints use a fixed value for the {endpoint} part, but utilize different subdomains for the {ip/domain} part.

Nonetheless, the Lantern dataset also contains scannable FHIR URLs, i.e., with fixed endpoint parts. We included the three most commonly used paths in an additional scan: '/v1/uscore/R4/metadata', '/fhir/r4/metadata', and '/fhirproxy/api/fhir/r4/metadata'. As a result, we found 659 further endpoints. Of these, 61 endpoints are part of the Lantern dataset, and 416 endpoints belong to systems identified in our initial scan. This again demonstrates that some FHIR hosts use multiple endpoints. Ultimately, we found minor overlap between our results and the Lantern dataset. Both datasets include six FHIR endpoints. After adding three endpoints for the scan method, the number of overlaps increased to 61.

Furthermore, we conducted an analysis of the authentication methods used by the endpoints in the Lantern dataset. Our analysis reveals that 28,783 endpoints support the combination of Smart-on-FHIR and OAuth, while 12,246 endpoints support only Smart-on-FHIR. A further 354 endpoints support the combination of Basic, Smart-on-FHIR and OAuth. One endpoint supports OAuth exclusively. For 10,059 endpoints, it was not possible to determine the authentication method from the metadata.

With regard to known vulnerabilities, we identified six FHIR endpoints in the Lantern dataset that suffer from at least one CVE-scored vulnerability. Four of these endpoints use an HAPI FHIR server and are affected by CVE-2024-51132. We found two endpoints that use the OpenEMR FHIR server and are affected by 74 vulnerabilities. From transport security perspective, all endpoints except one use TLS. We identified only one system through which patient data could be retrieved. This system contains exactly one patient.

Overall, the analysis of the Lantern dataset shows that the listed FHIR endpoints exhibit a significantly higher level of security than those identified using the scan method. One explanation could be that the FHIR endpoints in the Lantern dataset originate from FHIR developers and professional service providers and are intentionally made publicly accessible. Consequently, the FHIR endpoints have been secured by the operators.

G. Honeypot Portlist

The honeypot we have implemented listens on the following ports:

Table 11: List of all ports on which the honeypot is listening

Ports	Protocol
80	FHIR
443	FHIR
3000	FHIR
3005	FHIR
5000	FHIR
8000	FHIR
8081	FHIR
8082	FHIR
8083	FHIR
8085	FHIR
8089	FHIR
8090	FHIR
8888	FHIR
9000	FHIR
9080	FHIR
104	DICOM
2761	DICOM
2762	DICOM
11112	DICOM
4242	DICOM
4498	DICOM
2575	HL7
20046	HL7
2222	HL7

H. Disclosure Questionnaire

The following questions were included in the disclosure procedure:

- **Q1:** Were you aware that the system is accessible via the corresponding ports on the Internet? (yes/no)
- **Q2:** Are the systems intentionally exposed to the Internet? (yes/no)
- **Q3:** Will you reconfigure the systems so that they are no longer accessible on the Internet in the future? (yes/no)
- **Q4:** Is contacting you via the abuse email address the best way to inform you of possible security risks, or would you prefer an alternative method? (text)